

API SECURITY RISK ANALYSIS REPORT – TASK 3

Objective

The objective of this task is to analyze the security posture of sample public APIs using Postman, identify potential risks, and document recommendations for improving API security.

Tools Used

Postman

Google Chrome

Public Test API: <https://jsonplaceholder.typicode.com>

APIs Tested

GET /posts

GET /posts/1

GET /users

Methodology

Sent HTTP GET requests using Postman.

Examined API responses and HTTP status codes.

Reviewed publicly accessible data returned by the endpoints.

Documented observations related to authentication, data exposure, and security best practices.

Findings

1. Publicly Accessible Endpoints

Risk Level: Medium

Description:

The tested endpoints can be accessed without authentication.

Impact:

In a production environment, unrestricted access could expose data to unauthorized users.

Recommendation:

Require authentication (such as API keys, OAuth 2.0, or JWT) for endpoints that return sensitive information.

2. Potential Data Exposure

Risk Level: Low

Description:

The API returns structured user and post information in JSON format.

Impact:

If sensitive fields were included, excessive data exposure could increase privacy and security risks.

Recommendation:

Return only the minimum data required by clients and avoid exposing unnecessary information.

3. Rate Limiting Not Demonstrated

Risk Level: Medium

Description:

The public test API does not visibly demonstrate request rate limiting.

Impact:

Without rate limiting, APIs may be vulnerable to excessive automated requests or abuse.

Recommendation:

Implement request throttling and monitoring to reduce the risk of denial-of-service or misuse.

Risk Summary

Finding	Risk Level
Publicly Accessible Endpoints	Medium
Potential Data Exposure	Low
Rate Limiting Not Demonstrated	Medium

Evidence

GET /posts

GET Get data `https://jsonplaceholder.typicode.com/posts`

GET `https://jsonplaceholder.typicode.com/posts` Send

Query Params

Key	Value	Description	Bulk Edit
Key	Value	Description	

Body Cookies Headers 24 Test Results

200 OK • 617 ms • 7.98 KB

```
{
  "posts": [
    {
      "id": 1,
      "userId": 1,
      "title": "sunt aut facere repellat provident occaecati excepturi optio reprehenderit",
      "body": "quia et suscipit\nsuscipit recusandae consequuntur expedita et cum\nreprehenderit molestiae ut ut quas totam\nnostrum rerum est autem sunt rem eveniet architecto"
    },
    {
      "id": 2,
      "userId": 1,
      "title": "qui est esse",
      "body": "est rerum tempore vitae\nsequi sint nihil reprehenderit dolor beatae ea dolores neque\nfugiat blanditiis voluptate porro vel nihil molestiae ut reiciendis\nqui aperiam non debitis possimus qui neque nisi nulla"
    },
    {
      "id": 3,
      "userId": 1,
      "title": "ea molestias quasi exercitationem repellat qui ipsa sit aut",
      "body": "et iusto sed quo iure\nvoluptatem occaecati omnis eligendi ad ad\nvoluptatem doloribus vel accusantium quis pariatur\nmolestiae porro eius odio et labore et velit aut"
    }
  ]
}
```

GET /users

GET Get data `https://jsonplaceholder.typicode.com/users`

GET `https://jsonplaceholder.typicode.com/users` Send

Query Params

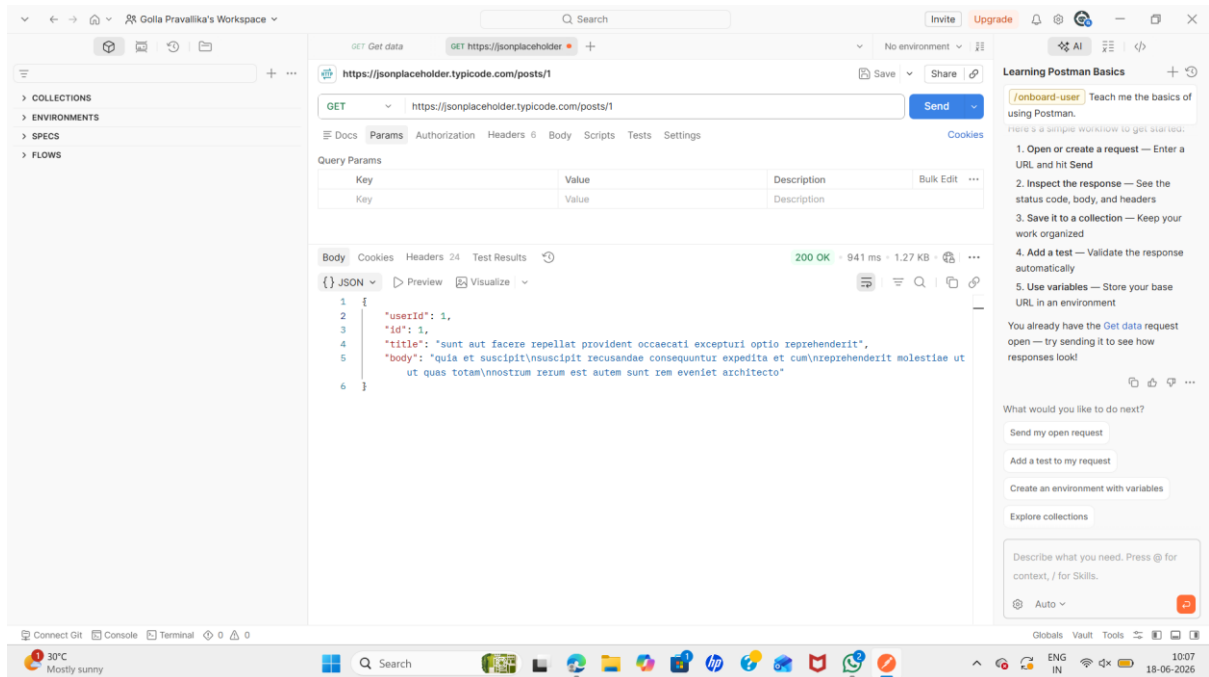
Key	Value	Description	Bulk Edit
Key	Value	Description	

Body Cookies Headers 26 Test Results

200 OK • 1.06 s • 2.93 KB

```
{
  "users": [
    {
      "id": 1,
      "name": "Leanne Graham",
      "username": "Bret",
      "email": "Sincere@april.biz",
      "address": {
        "street": "Kulas Light",
        "suite": "Apt. 556",
        "city": "Gwenborough",
        "zipcode": "92998-3874",
        "geo": {
          "lat": "-37.3159",
          "lng": "81.1496"
        }
      },
      "phone": "1-778-736-8031 x56442",
      "website": "hildegard.org",
      "company": {
        "name": "Romaguera-Crona",
        "catchPhrase": "Multi-layered client-server neural-net",
        "bs": "harness real-time e-markets"
      }
    }
  ]
}
```

GET /posts/1



Conclusion

The assessment demonstrated how APIs can be analyzed using Postman to identify common security considerations. Although the tested service is a public demonstration API designed for learning, the exercise highlights the importance of authentication, controlled data exposure, and rate limiting when designing production APIs.